Day 18 Homework: Govern your capstone

Mithran Sadasivam | AI Engineer Program, Phase 1, Week 4 | Repo: github.com/mithransadasivam/FDE, folder HW #18

Where I ended up

All three tasks are done. **overdue()** passes its 4 tests. My capstone, the Northwind IT Help Desk Chatbot, sorts as **limited risk under Article 50** of the EU AI Act. Its risk register has 9 risks across all four NIST functions and passes check_register.py with no overdue reviews. The most useful thing I found is that the chatbot has **no AI notice on its chat page**, and the Article 50 date (2 August 2026) has already gone by. That is my highest scored risk and I left it open on purpose, because I would rather show the gap than paper over it.

Task 1: overdue()

The function lives in app/risk_register.py. A risk counts as overdue when it is not mitigated and either its review_by date is before today or it has no review_by at all. I compare real dates with date.fromisoformat, not strings, and I return the ids in register order.

```
def overdue(risks, today=None):
    today = today or date.today()
    return [
        r["id"] for r in risks
        if r.get("status") != "mitigated"
        and (not r.get("review_by")
             or date.fromisoformat(r["review_by"]) < today)
    ]
```

Results: tests/test_overdue.py gives 4 passed. check_register.py prints "overdue reviews: none" for my register. I did not touch the tests.

One thing I should be upfront about: check_register() and classify_use_case() were still unfinished from the class activities, and Tasks 2 and 3 can't run without them. I filled both in following the rules in their docstrings (tests/test_risk_register.py 6 pass, tests/test_ai_act.py 7 pass). I did not do the bias test or the model card activities, since they aren't part of this homework. The full suite is 458 passed and 11 failed. All 11 are those two untouched activities (test_fairness, test_model_card).

Task 2: classifying the capstone

I read the code before answering, then checked each answer myself. The chatbot answers IT policy questions from seven documents with citations, declines when it has no source, and has agent tools for tickets where a person must approve any change.

Question	Answer	Why
Banned practice?	No	It only answers from company IT documents. Nothing in Article 5 fits.
Safety component of a product?	No	An internal help desk tool, not part of a regulated product.
Annex III area?	None	It decides nothing about hiring, pay, education, credit or benefits.
Narrow task (Art. 6(3))?	No (not needed)	That exception only matters if an Annex III area applied.

Question	Answer	Why
Profiles people?	No	It answers the question asked; no profile, and questions aren't stored.
Talks to people or generates content?	Yes	Staff chat with it and it writes answers itself.

Category: limited, Article 50 (the script says: "Article 50: transparency"). The obligation is to tell people they are talking to an AI, applying from 2 August 2026. I checked app/ui.py and the static chat page. The page says "IT Help Desk Assistant" and "Answers only from your team's documents", but never says it is an AI, so we are behind on this.

What would move it up: any feature that decides things about staff, for example ranking people by tickets raised for a performance review, or deciding who gets a laptop upgrade. That is Annex III point 4 (employment), high risk, and it also kills the Article 6(3) way out. I would ask compliance before building it.

Files: data/my_use_cases.json, governance/capstone_inventory.md, governance/capstone_classification.md (the justification, written by me).

Task 3: the risk register

I used the NIST questions in data/Day18_Slide25_nist_rmf_assessment.md and picked nine risks that are real for this chatbot, not generic ones. Owners are roles. Every piece of evidence is a file that exists in the repo, and check_register.py checks that.

Id	Risk	Function	Score	Owner	Status
C01	Staff are not told they are talking to an AI system: the chat page never says so (EU AI Act Article 50, in force since 2 August 2026)	GOVERN	16	IT Service Desk lead	open
C02	Nobody regularly reads the questions the chatbot declines or blocks, so wrong or missing answers go unnoticed	GOVERN	9	IT Service Desk lead	open
C03	A question or a planted document contains instructions that change the chatbot's answers (prompt injection)	MAP	12	Chatbot product owner	mitigated
C04	An agent tool changes or reassigns a help desk ticket wrongly, or a role is given tools it should not have	MAP	8	Chatbot product owner	mitigated
C05	The chatbot gives a wrong or uncited answer and staff act on it	MEASURE	9	Chatbot product owner	mitigated
C06	Routing simple questions to the small model makes answers worse (it failed the quality gate: wrong P1 response time)	MEASURE	9	Chatbot product owner	mitigated
C07	The model provider is down or slow and staff get no answers	MANAGE	9	Platform on-call engineer	mitigated
C08	Personal data from a question or a document shows up in an answer or a log	MANAGE	8	Data protection lead	mitigated

Id	Risk	Function	Score	Owner	Status
C09	Heavy use or an agent that keeps calling tools runs up the model bill	MANAGE	4	Chatbot product owner	accepted

Run: **Register governance/capstone_risk_register.json: PASS (9 risks)**. By function: GOVERN 2, MAP 2, MEASURE 2, MANAGE 3. Overdue reviews: none.

The accepted risk (C09, runaway cost). Accepted by the IT Service Desk lead because the cost report puts the bill at about $62 a month for 10,000 questions a day and the agent stops after 6 steps, so the worst case is a few cents per question.

The two open ones. C01 (no AI notice) is the one I would fix first: it is the only risk that is already a legal obligation, and the fix is one visible line. C02 (nobody reads declined questions) is open because the dashboard and alerts exist but no person is assigned to look at them regularly.

C06 is worth a mention. Back on Day 16 the small routing model failed the quality gate (it gave a 4 hour P1 response time when the policy says 15 minutes), so routing is off by default. That's a control that lives in config rather than in the model's good behaviour, and logs/quality_recheck_routing.txt shows the failure.

What I would do next

Add the AI notice to the chat page and the /ask response, then flip C01 to mitigated with a test as the evidence. Name a person (a role) who reviews declined and blocked questions every week. And set a calendar reminder to run overdue() on a schedule, because a check that runs once is the same as no check.